Password and Authentication Standard

1 Purpose and scope

This standard describes how passwords for Halvenroot accounts are chosen, protected and managed, and how Halvenroot systems protect the sign-in process against guessing attacks.

It applies to all employees, contractors and any other personnel who have an account on a Halvenroot system, whether that system is in a Halvenroot office, a warehouse site or a hosted service that Halvenroot uses. It covers user passwords. Multi-factor authentication is set by the Multi-Factor Authentication Standard, and privileged credentials are set by the Privileged Access Standard.

This version replaces version 1.0, which took effect on 2024-03-01.

2 Roles

- **Every user** follows this standard, protects their own passwords and reports any password they believe has been exposed.
- **The IAM team** configures the identity portal so that it enforces the rules in sections 4 and 5, and maintains the password blocklist.
- **System owners** make sure that the systems they own, where they keep their own passwords, meet the same rules.
- **Resource owners** decide who may use the resources they own and grant that access to individual accounts.
- **The IT Service Desk** helps users with sign-in problems and with the self-service reset. It never asks a user for their password.
- **The Security Operations Centre** receives reports of exposed or compromised passwords and decides what further action is needed.

3 Definitions

Terms such as privileged account, break-glass account and business day are defined in the Halvenroot Security Glossary.

4 Password rules

4.1 Minimum length

Passwords must be at least 15 characters long. A passphrase made of several unrelated words is an easy way to meet this rule and is encouraged.

4.2 Long passwords

Systems must accept passwords of at least 64 characters. Systems must not cut a password short without telling the user, and must accept spaces and printable characters.

4.3 Composition and blocklist

Halvenroot does not impose composition rules (such as requiring a mix of character types). New passwords are checked against a blocklist of common and breached passwords. A password that appears on the blocklist is rejected, and the identity portal asks the user to choose another one.

4.4 Expiry

User passwords expire every 60 days. When a password expires, the user chooses a new one that meets sections 4.1 to 4.3.

Service account and break-glass credentials are not user passwords; they follow the Privileged Access Standard, sections 6 and 7.

4.5 Compromised passwords

If you know or suspect that a password has been compromised, change it immediately and report it to the Security Operations Centre within 1 hour. Report it even if you have already changed the password, and even if you are not sure. The Security Operations Centre handles the report under the Account-Compromise Incident Runbook.

4.6 Protecting passwords

All passwords are confidential information. Never share your password with anyone, including the IT Service Desk. If someone asks you for your password, refuse and tell the Security Operations Centre.

Do not write passwords down, and do not keep them in email, chat messages or notes. Store work passwords only in the approved password manager; its autofill feature may be used. Do not reuse a Halvenroot password for any other account, work or personal.

If a colleague needs access to your work while you are away, the resource owner grants them their own access.

4.7 Self-service reset

Self-service password reset in the Halvenroot identity portal requires MFA. Security questions are not used. If you cannot complete the self-service reset, contact the IT Service Desk, which verifies your identity before helping you.

5 Sign-in protection

Table 1 sets the sign-in protection values for all Halvenroot accounts.

Table 1: Sign-in protection values

Control	Standard accounts	Privileged accounts
Failed sign-in attempts before lockout	10	5
Counting window for failed attempts	15 minutes	15 minutes
Lockout duration	30 minutes	Until the IAM team unlocks the account
Delay after the 3rd consecutive failed attempt	30 seconds, doubling after each further failure	30 seconds, doubling after each further failure
Maximum delay between attempts	10 minutes	10 minutes

6 External guidance

This standard was prepared with reference to NIST SP 800-63B-4 and the UK NCSC password guidance; excerpts of both are kept with this pack. The excerpts are reference material only. The rules that apply to Halvenroot accounts are the ones set out in this standard.

7 Exceptions

Exceptions to this standard follow the Policy Exceptions Process. An exception applies only after it has been approved, and only to the accounts and systems named in it.

8 Enforcement

The IAM team enforces sections 4 and 5 through the identity portal wherever the portal allows it. Where a system cannot enforce a rule, its system owner records the gap and requests an exception.

An employee or contractor found to have violated this standard may be subject to disciplinary action, up to and including termination of employment or contract. Halvenroot may also suspend an account while a suspected violation is investigated.

9 Document control

- **Owner:** IAM team
- **Approver:** CISO
- **Version:** 2.0 (replaces version 1.0)
- **Effective date:** 2025-09-01

Adapted from strongdm/comply (Apache-2.0); changed by the ai-testing-rag-lab authors.